



UNIVERSIDAD POLITÉCNICA METROPOLITANA DE HIDALGO

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN
“9-A”

SEGURIDAD INFORMÁTICA

Propuesta de solución para el caso de estudio

Dr. Carlos Alberto Carrillo Santos

Equipo 4

Escalante Salas, Emiliano

Laureles Martínez, Humberto

Luna Santillán, Alexis

Morales Téllez, Edgar Osvaldo

Tolcayuca, Hgo; a 23 de septiembre de 2025.

PASO 1: Análisis inicial

A continuación, se describen 8 riesgos principales derivados de la falta de políticas de seguridad y una relación con los activos más críticos en la empresa:

1. Compromiso de credenciales por contraseñas débiles/compartidas

- **Qué puede pasar:** accesos no autorizados a correo, VPN, AD; movimiento lateral; robo de datos.
- **Activos afectados:** Active Directory, Microsoft 365 (correo/OneDrive/SharePoint), VPN corporativa, servidores internos, suscripciones/recursos en Azure, datos de clientes.

2. Exfiltración de datos vía USB/dispositivos externos no controlados

- **Qué puede pasar:** copia de información confidencial y salida de la red sin trazabilidad.
- **Activos afectados:** datos de clientes, propiedad intelectual, documentación interna sensible, endpoints corporativos.

3. Uso indebido de privilegios (admins de sistemas, cuentas de servicio)

- **Qué puede pasar:** cambios no autorizados, borrado de evidencias, creación de puertas traseras, abuso de acceso a producción.
- **Activos afectados:** AD (controladores de dominio, GPOs), servidores internos, Azure (RBAC, claves, secretos), herramientas de administración.

4. Ausencia de clasificación de información

- **Qué puede pasar:** documentos sensibles circulan sin cifrado ni controles; se comparten por error a terceros; mala retención/eliminación.
- **Activos afectados:** datos de clientes, contratos, reportes financieros, repositorios de documentación, SharePoint/Teams/OneDrive.

5. Software no autorizado (“shadow IT” en endpoints)

- **Qué puede pasar:** malware, puertas traseras, incompatibilidades, fuga de datos por apps de terceros, problemas de licenciamiento.

- **Activos afectados:** endpoints, red interna, datos en Microsoft 365, autenticación corporativa (token stealers).

6. Controles débiles en acceso remoto (configuración de VPN, MFA incompleto)

- **Qué puede pasar:** acceso externo con credenciales robadas, ataques de fuerza bruta, exposición de servicios.
- **Activos afectados:** VPN, AD, servidores internos, Azure.

7. Registro y monitoreo insuficientes (telemetría/logs dispersos)

- **Qué puede pasar:** detección tardía de incidentes, falta de evidencia forense, brechas no contenidas.
- **Activos afectados:** SIEM/Log Analytics, M365 audit logs, Azure Activity Logs, controladores de dominio, firewalls/VPN.

8. Gestión deficiente de parches y configuraciones

- **Qué puede pasar:** explotación de vulnerabilidades conocidas, escalamiento de privilegios, ransomware.
- **Activos afectados:** endpoints, servidores, controladores de dominio, appliances VPN, servicios PaaS/IaaS en Azure.

A continuación, se muestra una tabla donde se muestra su probabilidad x impacto en cada uno de los riesgos mencionados anteriormente:

Riesgo	Prob.	Impacto	Prioridad sugerida
Contraseñas débiles/compartidas	Alta	Alta	Crítica
USBs no controlados	Media	Alta	Alta
Privilegios indebidos	Media-Alta	Crítica	Crítica
Sin clasificación de info.	Media	Alta	Alta
Software no autorizado	Alta	Media-Alta	Alta
Acceso remoto débil	Media	Alta	Alta
Monitoreo insuficiente	Media	Media-Alta	Media-Alta
Parches/config. débiles	Media	Alta	Alta

PASO 2: Definición de Políticas

A continuación, se muestran 5 políticas de seguridad obligatorias que se deben cumplir:

1. Política de Contraseñas y Autenticación (incluye MFA)

Objetivo

Establecer requisitos de autenticación robusta para reducir accesos no autorizados a AD, Microsoft 365, VPN, servidores y Azure.

Alcance

Todo el personal, cuentas de servicio, proveedores con acceso y sistemas corporativos (on-prem y nube).

Responsabilidades

- **TI/Seguridad:** configurar MFA y políticas de contraseña; monitorear cumplimiento.
- **Usuarios:** custodiar credenciales; cumplir los requisitos; reportar incidentes.
- **Dueños de sistemas:** aplicar estos controles en sus aplicaciones.

Reglas obligatorias

1. **MFA** habilitado para **todas** las cuentas humanas (AD/Azure AD/M365/VPN).
2. **Contraseñas**: mínimo 14 caracteres, mezcla de tipos, sin patrones obvios ni reutilización entre sistemas.
3. **Bloqueo** por intentos fallidos (p. ej., 10 intentos/15 min); enfriamiento automático.
4. **Gestor de contraseñas** corporativo para almacenamiento; **prohibido** compartir contraseñas.
5. **Cuentas de alto privilegio**: autenticación reforzada (MFA + restricciones de ubicación/dispositivo).
6. **Cuentas de servicio**: sin MFA, pero con **secretos rotados** y **permisos mínimos**; inventario y dueño asignado.
7. **Recuperación de acceso**: proceso formal verificado por TI (sin intercambio por chat/correo).
8. **VPN**: solo acceso con MFA y dispositivo conforme.

Excepciones

Vía mesa de seguridad, con justificación técnica, periodo definido y control compensatorio.

Violaciones

Suspensión temporal de acceso y acciones disciplinarias conforme al reglamento interno.

2. Política de Uso de Dispositivos Externos (USB, smartphones y BYOD)

Objetivo

Para evitar que se filtren datos importantes de la empresa o que entren virus usando memorias USB, celulares o computadoras personales.

Alcance

Endpoints corporativos (Windows/macOS/Linux), móviles, USB, discos externos, smartphones (corporativos o de uso personal).

Responsabilidades

- **TI/Seguridad**: aplicar controles en endpoints; solo permitir USB o celulares que cumplan con las reglas ; tener registro de qué dispositivos están aprobados.
- **Usuarios**: usar únicamente dispositivos permitidos; reportar pérdidas/robos.

Reglas obligatorias

1. **USB de almacenamiento bloqueados por defecto.** Excepciones: **USB cifrados corporativos** aprobados.
2. **Lectura/escritura** en USB solo para roles autorizados y con registro.
3. **Smartphones:** acceso a (correo/apps de trabajo) debe de tener instalada la app de seguridad de la empresa y (bloqueo/cifrado) del dispositivo.
4. **BYOD:** Debes registrarlo con la empresa; separación de datos corporativos y personales.
5. **Prohibido** copiar datos **Confidenciales/Restringidos** a medios no cifrados o no inventariados.
6. Pérdida/robo de dispositivo: **reporte inmediato** para borrado remoto.

Excepciones

Que de autorización el jefe o área de la empresa; tiempo acotado y registro del caso.

Violaciones

Retiro del dispositivo, reporte a Recursos Humanos. y medidas conforme a política disciplinaria.

3. Política de Administración de Privilegios (AD/Azure/Infra)

Objetivo

Controlar y auditar el uso de privilegios para minimizar abuso, errores y o que un atacante se mueva libremente y poder ver que hizo y cuando.

Alcance

AD "Active directory"/Azure AD "donde se gestionan usuarios", Microsoft 365, servidores locales como la oficina, IaaS/PaaS en Azure "servicios en la nube(máquinas virtuales)", bases de datos y herramientas de administración.

Responsabilidades

- **Seguridad/TI:** definir roles, aprobar cuando necesiten permisos especiales, auditar accesos privilegiados.
- **Dueños de sistemas:** Deciden qué permisos necesita cada puesto; revisar permisos trimestralmente.

- **Usuarios privilegiados:** usar cuentas separadas y cumplir con registros.

Reglas obligatorias

1. **Mínimo privilegio y separación de funciones (SoD)** en todos los sistemas.
2. **Cuentas separadas:** una de trabajo estándar y otra **solo** para tareas administrativas.
3. **Elevación Just-In-Time (JIT)** mediante herramienta de gestión de identidades privilegiadas (PIM/PAM), con **tiempo limitado** y escribir por qué lo necesitas.
4. **Prohibido** el uso de cuentas genéricas de administrador; si existiera una cuenta “break-glass”, debe tener dueño, custodia y monitoreo.
5. **Revisión trimestral** de accesos privilegiados y cuentas de servicio (alta/baja/cambio).
6. **Acceso a producción:** bajo cambio autorizado, sesión grabada o con un registro claro de lo que se hizo.

Excepciones

Procedimiento de emergencia con ticket, aprobación del responsable de Seguridad y expiración automática.

Violaciones

Revocación de privilegios y acciones disciplinarias conforme a normativa interna.

4. Política de Clasificación y Manejo de la Información

Objetivo

Asegurar que la información se proteja según su sensibilidad durante todo su ciclo de vida.

Alcance

Documentos, correos, repositorios, bases de datos y registros en plataformas corporativas (on-prem y nube).

Responsabilidades

- **Dueños de la información:** asignar la **clasificación** y revisar periódicamente.
- **Usuarios:** respetar etiquetas/controles; compartir según nivel.
- **Seguridad/TI:** proveer herramientas de etiquetado, cifrado y prevención de fuga.

Reglas obligatorias

1. Niveles de clasificación:

- **Pública, Interna, Confidencial, Restringida.**

2. **Etiquetado visible** (encabezado/pie o etiqueta digital) y, donde aplique, **cifrado** automático para **Confidencial/Restringida**.

3. **Compartición:**

- Púb./Interna: solo con personal/terceros autorizados.
- Confid./Restringida: **prohibido** compartir fuera de la compañía sin NDA y autorización del dueño.

4. **Correo/Teams/SharePoint/OneDrive:** aplicar **etiquetas de sensibilidad** y restricciones de reenvío/descarga según nivel.

5. **Retención y eliminación:** cumplir con periodos definidos; eliminación segura al fin del ciclo.

6. **Transferencias** fuera de la red: solo por canales aprobados (cifrado en tránsito y en reposo).

Excepciones

Autorización del dueño del dato + Seguridad; registro del caso y controles compensatorios.

Violaciones

Notificación a Seguridad, posible reporte regulatorio y acciones disciplinarias.

5. Política de Instalación y Uso de Software Corporativo

Objetivo

Evitar software no autorizado que introduzca riesgos técnicos, legales o de fuga de información.

Alcance

Todos los equipos corporativos, servidores y cuentas de usuario; aplica a software de escritorio, extensiones, scripts y servicios.

Responsabilidades

- **TI:** mantener catálogo/“lista blanca” y canal oficial de distribución; parchar y retirar software obsoleto.

- **Usuarios:** solicitar altas de software por el canal formal; **prohibido** instalar por cuenta propia.

Reglas obligatorias

1. **Solo software aprobado** por el catálogo corporativo e instalado vía herramienta de gestión (ej. portal/agent corporativo).
2. **Prohibidas** tiendas no autorizadas, cracks, herramientas de TOR/VPN personales y descargas fuera del canal oficial.
3. **Solicitudes de nuevo software:** evaluación de seguridad/licenciamiento/soporte antes de aprobar.
4. **Extensiones de navegador:** solo desde catálogo aprobado.
5. **Escaneo** de endpoints con EDR/antimalware; **desinstalación** forzada de software no aprobado.
6. **Roles de desarrollador:** repositorios y toolchains aprobados; uso de **secret scanning** y políticas de dependencias.

Excepciones

Solo con ticket aprobado por TI y Seguridad; plazo definido y revisión de riesgos.

Violaciones

Remoción del software, posible bloqueo del equipo y acciones disciplinarias.

PASO 3: Mecanismos de control

3.1 Política de Contraseñas y Autenticación (MFA)

Controles técnicos (ejemplos concretos)

- **Entra ID (Azure AD) / Microsoft 365**
 - Reglas de **Conditional Access** para exigir MFA a todos los usuarios (excepciones controladas).
 - **Identity Protection:** detección de **sign-ins riesgosos** y usuarios en riesgo.
 - **Password Protection** (lista de contraseñas prohibidas + Smart Lockout).
 - **SSPR** (Self-Service Password Reset) con comprobaciones seguras.
 - **WHfB/FIDO2** para admins y puestos sensibles.

- **Active Directory on-prem**
 - **Fine-Grained Password Policies (PSO).**
 - **GPO** para bloquear caché de credenciales débiles en equipos, y exigir bloqueo tras intentos fallidos.
- **VPN**
 - Integrar con Entra ID/Radius para que **siempre** solicite MFA y sólo desde **dispositivo conforme**.

Auditoría / Verificación

- **Logs** de inicio de sesión (Entra ID Sign-in logs), **Risky sign-ins**, **Audit logs** (activaciones/desactivaciones MFA).
- Reportes de **usuarios con MFA** en Entra ID/Intune.
- **SIEM** (Microsoft Sentinel o equivalente) correlando eventos de AD, M365 y VPN.

KPIs (indicadores)

- **% de usuarios con MFA activo** (meta $\geq 98\%$; admins 100%).
- **% de cuentas privilegiadas con FIDO2/WHfB** (meta $\geq 95\%$).
- **Tasa de inicios de sesión fallidos** por usuario/semana (tendencia a la baja).
- **Tiempo medio de deshabilitar cuentas comprometidas** (MTTR < 30 min).
- **# de eventos de Smart Lockout** por mes (debe disminuir tras campañas).

3.2 Política de Dispositivos Externos (USB / BYOD / móviles)

Controles técnicos

- **Intune / Defender for Endpoint**
 - **Device Control / ASR:** bloquear **clases de almacenamiento USB** por defecto; permitir sólo **USB cifrados corporativos**.
 - **BitLocker** obligatorio para medios aprobados.
 - **Compliance policies + Conditional Access:** sólo acceden a M365 los **dispositivos conformes**.

- **App Protection Policies (MAM)** para separar datos corporativos en BYOD.
- **GPO (Windows) / Config Profiles (macOS)**
 - Bloqueo de **removable storage** no autorizado.
- **MDM en móviles** (iOS/Android)
 - Cifrado, PIN, borrado remoto, bloqueo de copia/pega hacia apps no corporativas.

Auditoría / Verificación

- Informes de **Intune** (dispositivos inscritos, cumplimiento, Device Control).
- Alertas de **Defender for Endpoint** sobre conexión/uso de USB y copia a medios removibles.
- **DLP de M365** con regla específica para “**removable media**” (registra y bloquea).

KPIs

- **% de endpoints con USB bloqueado por defecto** (meta $\geq 95\%$).
- **% de móviles/BYOD inscritos en MDM/MAM** (meta $\geq 95\%$).
- **# de incidentes DLP por intento de copiar a USB** (tendencia a la baja).
- **% de USB aprobados inventariados y cifrados** (meta 100%).

3.3 Política de Administración de Privilegios (AD/Azure/Infra)

Controles técnicos

- **PIM (Privileged Identity Management)** en Entra ID / Azure: **JIT** con aprobación, duración limitada y razón.
- **RBAC** estricto en Azure/M365 (sin “Owner” permanentes; usar roles mínimos).
- **Cuentas separadas** (estándar vs admin) + **PAW** (Privileged Access Workstations) para tareas admin.
- **Windows LAPS** para contraseñas locales aleatorias y rotadas.
- **GPO** para impedir que usuarios estándar tengan derechos locales de admin.
- **Tiering** lógico (separación de administración de DCs/servidores/usuarios).

Auditoría / Verificación

- **PIM logs** (activaciones, aprobaciones, denegaciones).
- **Azure Activity Logs, M365 Audit, AD Security logs** (alta/baja de grupos 4728/4729, creación de cuentas 4720, etc.).
- Revisiones **trimestrales** de acceso privilegiado (certificación de accesos) firmadas por dueños de sistemas.

KPIs

- **# de asignaciones privilegiadas permanentes** (meta: 0 o mínima justificada).
- **% de activaciones JIT con aprobación previa** (meta 100%).
- **% de revisiones trimestrales completadas en fecha** (meta $\geq 95\%$).
- **# de inicios de sesión admin desde equipos no-PAW** (meta 0).

3.4 Política de Clasificación y Manejo de la Información

Controles técnicos

- **Microsoft Purview Information Protection**
 - **Etiquetas de sensibilidad** (Pública/Interna/Confidencial/Restringida) con **cifrado y marcado** automático donde aplique.
 - **Auto-labeling** por tipos de datos (PII, financieros, contratos).
- **DLP en M365/Endpoints**
 - Reglas para bloquear/alertar sobre movimientos de **Confidencial/Restringida** (correo, Teams, SharePoint/OneDrive, endpoints).
- **External Sharing / Session Controls**
 - Límites de compartición externa; **Conditional Access** con **session controls** (bloquear descargar/imprimir para datos sensibles).
- **AIP Scanner / Sensitivity en repos on-prem**
 - Descubrir y etiquetar datos sensibles fuera de M365.

Auditoría / Verificación

- Reportes de **M365 DLP, Purview (etiquetas), SharePoint/OneDrive** (compartición externa).
- **SIEM**: correlación de eventos DLP, cambios de permisos, accesos inusuales.

KPIs

- **% de contenido etiquetado** (meta inicial $\geq 80\%$; aumentar con auto-label).
- **# de incidentes DLP bloqueados** (medir tendencia; objetivo: baja sostenida).
- **% de sitios con compartición externa restringida** (meta $\geq 95\%$).
- **% de archivos Confid./Restringida en ubicaciones aprobadas** (meta $\geq 98\%$).

3.5 Política de Instalación y Uso de Software

Controles técnicos

- **Intune / ConfigMgr**: catálogo de **apps aprobadas**, despliegue y **medición de cumplimiento**.
- **WDAC / AppLocker**: **lista blanca** obligatoria (deny-by-default) por grupos de equipos/roles.
- **Defender for Endpoint** (EDR/EPP): detección de PUA, bloqueo de procesos maliciosos y **exfiltración por apps**.
- **Vulnerability Management** (Defender VM u otra): parches y updates por **anillos**; SLA por criticidad.

Auditoría / Verificación

- Inventario de software (Intune/Defender), **detección de apps no aprobadas** y desinstalación forzada.
- Reportes de **actualizaciones y cumplimiento de parches**.
- Alertas del **SIEM** por ejecución de binarios fuera de lista blanca.

KPIs

- **% de endpoints con WDAC/AppLocker en modo “enforce”** (meta $\geq 90\%$ fase 1; $\geq 98\%$ fase 2).
- **% de endpoints con parches críticos ≤ 7 días** (meta $\geq 95\%$).

- **# de instalaciones no autorizadas remediadas** por mes (tendencia a la baja).
- **Tiempo medio de despliegue de un parche crítico** (SLA según severidad).

3.6 Monitoreo central y evidencias

- **SIEM (Microsoft Sentinel u otro):** ingestión de Entra ID, M365, Defender, Azure Activity, AD on-prem, firewalls/VPN (Syslog), servidores críticos.
- **Casos de uso (detecciones):**
 - Inicio de sesión sin MFA, activación privilegiada fuera de horario, copia masiva hacia USB, compartición externa de documentos clasificados, ejecución de binarios fuera de lista blanca, picos de inicios fallidos/VPN.
- **Retención de logs:** mínimo **180 días** (ideal 365), acorde a regulaciones.
- **Evidencias de auditoría:** reportes mensuales de KPIs, bitácoras de revisiones trimestrales de accesos, actas de comité de seguridad.

3.7 Umbrales de alerta (sugeridos)

- **MFA admins < 100% → Alerta crítica.**
- **Asignaciones privilegiadas permanentes > 0** (sin justificación) → **Alerta alta.**
- **USB bloqueado < 90%** de endpoints → **Alerta alta.**
- **Parche crítico fuera de SLA (> 7 días)** en > 5% endpoints → **Alerta alta.**
- **DLP: > 10 incidentes/semana** de “Confidencial” hacia USB o externos → **Alerta alta.**

3.8 Cadencia de revisión

- **Diaria:** Alertas SIEM, activaciones PIM, inicios riesgosos, incidentes DLP.
- **Semanal:** Reporte de cumplimiento (MFA, USB, WDAC, parches), tendencias de incidentes.
- **Mensual:** KPI consolidado a dirección; revisión de excepciones vigentes.
- **Trimestral:** Re-certificación de accesos privilegiados; auditoría de compartición externa y software instalado.

- **Anual:** Prueba de “break-glass”, simulacros de respuesta a incidentes y tabletop de fuga de datos.

PASO 4: Plan de implementación

A continuación, se muestra en la siguiente tabla la asignación de responsables por cada área:

Actividad / Control	Seguridad de la Info (CISO)	TI/Infra & Endpoints	Identidades/AD & M365	Dueños de Datos	RR. HH.	Legal/Compliance	Comunicación Interna
Pol. Contraseñas/MFA (Conditional Access, PSO)	A/R	C	R	I	I	C	I
Bloqueo USB / BYOD (Intune/MDM)	A/R	R	C	I	I	C	I
PIM/JIT y RBAC (privilegios)	A/R	C	R	I	I	C	I
Clasificación/DLP (Purview/M365)	A/R	C	R	R	I	C	I
Lista blanca de software (WDAC/AppLocker)	A/R	R	C	I	I	I	I
SIEM/Sentinel, casos de uso y KPIs	A/R	R	R	I	I	C	I
Campañas, phishing sim y cursos	A	I	I	I	R	C	R
Gestión de excepciones y sanciones	A	C	C	C	R	R	I

Uso de llenado de tabla:

- **R** = Responsable de ejecución
- **A** = Aprueba
- **C** = Consultado
- **I** = Informado.

4.2 Cronograma por fases (90 días + expansión a 12 meses)

Fase 0 – Preparación (Semana 0–1)

- Comité de programa (CISO, TI, Identidades, RR. HH., Legal).
- Congelar alcance versión 1.0 de políticas (las 5 ya redactadas).
- Alinear métricas (KPIs del Paso 3) y tablero en Power BI/Workbook de Sentinel.
- Plan de comunicación (tono, piezas, calendario).

Entregables: Charter del programa, políticas v1.0, tablero KPI inicial.

Fase 1 – Quick Wins (Días 1–30)

- 1. MFA “en todos” + admins 100%**
 - Regla de Conditional Access; exclusiones temporales aprobadas.
- 2. Bloqueo USB por defecto**
 - Intune/Defender Device Control; permitir solo USB cifrados corporativos.
- 3. Cuentas separadas admin/usuario + LAPS**
 - Crear cuentas admin personales; habilitar Windows LAPS y retirar admins locales.
- 4. DLP básico en M365**
 - Plantillas listas (PII, clientes) con modo auditar/bloquear para Confidencial/Restringida.
- 5. Catálogo de software**
 - Publicar lista blanca mínima y canal oficial de instalación.

Comunicación y training (Ola 1):

- Infografía MFA y USB (5 minutos), micro-video de 2 min, guía “cómo pedir excepciones”.
- Curso e-learning corto (15–20 min) con quiz.

Hitos/KPIs meta al día 30:

- ≥ 98% usuarios con MFA activo; 100% admins.

- $\geq 90\%$ endpoints con USB bloqueado.
- 100% cuentas admin separadas con LAPS.

Fase 2 – Endurecimiento y visibilidad (Días 31–60)

1. **PIM/JIT para privilegios** (admins globales, owners en Azure/M365).
2. **Etiquetas de sensibilidad** en Purview + **auto-label** piloto (contratos/PII).
3. **WDAC/AppLocker** en “audit” → grupos piloto en “enforce”.
4. **SIEM/Sentinel**: casos de uso prioritarios (MFA faltante, elevaciones JIT, exfil USB, compartición externa).
5. **Compliance/BYOD**: MDM/MAM obligatorio para correo y apps M365 en móviles.

Comunicación y training (Ola 2):

- Taller de 1 hora a **dueños de datos** (cómo clasificar, compartir y solicitar excepciones).
- Cápsulas de 5 min para equipos con rol admin (PIM/JIT, PAW).

Hitos/KPIs meta al día 60:

- 100% privilegios críticos detrás de PIM/JIT.
- $\geq 60\%$ contenido nuevo con etiqueta aplicada.
- $\geq 70\%$ móviles/BYOD inscritos en MDM/MAM.
- WDAC/AppLocker “enforce” en $\geq 40\%$ de endpoints objetivo.

Fase 3 – Cierre v1.0 y operación continua (Días 61–90)

1. **Revisión trimestral de accesos** (certificación de privilegios).
2. **DLP expandido** (bloqueo + coaching) en SharePoint/OneDrive/Teams + Endpoints.
3. **WDAC/AppLocker** a “enforce” en $\geq 90\%$ (excepciones documentadas).
4. **Panel ejecutivo** de KPIs y alertas con metas y tendencias.
5. **Proceso de gestión de excepciones** formal (plantilla, duración, control compensatorio).

Comunicación y training (Ola 3):

- Simulación de **phishing** (campana base).
- Guía “Top 10 dudas frecuentes” y office hours quincenales 30 min.

Hitos/KPIs meta al día 90:

- $\geq 80\%$ contenido etiquetado; compartición externa controlada $\geq 95\%$.
- $\geq 95\%$ BYOD/MDM conformes.
- Parcheo crítico ≤ 7 días en $\geq 95\%$ endpoints.
- Reporte mensual a dirección con incidencias DLP, PIM y USB.

Ruta 6–12 meses (Madurez)

- **Zero Trust** por segmentos: PAW para admins, segmentación de red, hardening de DCs.
- **Clasificación avanzada** (auto-label por ML en repos on-prem vía AIP Scanner).
- **Procesos SOAR** (automatizar respuesta: deshabilitar cuentas comprometidas, revocar sesiones).
- **Tabletops** semestrales (fuga de datos, ransomware).
- **Ciclo de vida de proveedores** (NDA + controles para externo).

4.3 Estrategia de concientización y cambio cultural

- **Mensajes claros y breves** (una idea por pieza, call-to-action concreto).
- **Embajadores de seguridad** por área (1 por cada 50–70 empleados).
- **Formato mixto**: infografías, micro-videos, pop-ups en M365, fondos de pantalla con tips.
- **Simulaciones de phishing**: base (día 75), luego **trimestrales** con coaching a quien falle.
- **Cursos e-learning**:
 - General (20 min) anual + mini-módulos por tema (MFA, DLP, USB, PIM).

- Rutas específicas para **admins** y **dueños de datos**.
- **Gamificación:** ranking por áreas, insignias a > 95% cumplimiento.

4.4 Gestión de excepciones y disciplina

- **Excepciones:** ticket con justificación, riesgo, controles compensatorios, **fecha de expiración**, responsable.
- **Revisión mensual** de excepciones vigentes.
- **Violaciones:** flujo con RR. HH. y Legal; medidas proporcionales y trazables.

4.5 Presupuesto y compras (alto nivel)

- **Licencias:** Entra ID P1/P2, Defender for Endpoint, Intune, Purview, Sentinel (o equivalentes).
- **Hardware:** USB cifrados corporativos, PAWs para admins, almacenamiento de logs.
- **Servicios:** horas de consultoría para PIM/WDAC/DLP inicial y capacitación especializada.
- **Tiempo de equipos:** ventana de mantenimiento para despliegues y pruebas piloto.

4.6 Gobierno continuo (run-state)

- **Comité mensual** (CISO + líderes) para revisar KPIs, incidentes y excepciones.
- **Revisión trimestral** de políticas y mapa de riesgos; actualización de casos de uso del SIEM.
- **Auditorías internas** semestrales (muestras: MFA, PIM, DLP, WDAC, BYOD).
- **Reporte ejecutivo** mensual (tendencias, brechas, acciones correctivas).

Checklist de salida (v1.0 listo)

- MFA global con reporte $\geq 98\%$ (admins 100%).
- USB bloqueado por defecto, inventario de medios cifrados.
- PIM/JIT activo y **cero** privilegios permanentes no justificados.
- Etiquetas y DLP operando; guía de clasificación publicada.
- WDAC/AppLocker “enforce” en $\geq 90\%$ endpoints objetivo.
- SIEM con casos de uso y tablero de KPIs entregado a dirección.
- Campaña de concientización ejecutada (curso + phishing sim).
- Proceso de excepciones y sanciones vigente.